SLOVENSKÁ TECHNICKÁ UNIVERZITA V BRATISLAVE

Fakulta elektrotechniky a informatiky

Inteligentný systém pre automatizované hodnotenie bezpečnosti a governance AI systémov

Tímový projekt (TP1)

Projektová dokumentácia

Tím: Ivan Yachmenov (I-API-AI)
Viacheslav Kolesnikov (I-API-ISS)
Hlib Dorosh (I-API-ISS)
Ihor Shpetun (I-API-AI)
Dmytro Loiko (I-API-ISS)

Vedúci projektu: Lukáš Šurab

Spolupráca: Alison Slovakia s.r.o.

Bratislava **akademický rok 2026/2027**

Obsah

Úvod **5**

1 Oficiálne zadanie **6**

2 Tím a ponuka **8**

3 Ciele riešenia **9**
3.1 Hlavný cieľ 9
3.2 Čiastkové ciele 9

4 Analýza problematiky **10**
4.1 Východiská problému 10
4.2 Požiadavky a taxonómie 10
4.3 Existujúce riešenia podobné cieľu projektu 11
4.4 Nástroje na hodnotenie a testovanie modelov 12
4.5 Riešenia s orchestráciou agentov 13
4.6 Čo z existujúcich riešení využijeme 14
4.7 Vymedzenie riešeného problému 14

5 Návrh a architektúra systému **16**
5.1 Princípy návrhu 16
5.2 Komponenty systému 17
5.3 Orchestrátor a agenti 17
5.4 Informačný model profilu 19
5.5 Nasadenie 20
5.6 Priebeh auditu 20

6 Špecifikácia extrahovaných atribútov a verifikácie profilu modelu **23**
6.1 Kategória 1: Identita a pôvod modelu (Model Identity & Provenance) . 24
6.2 Kategória 2: Dáta a trénovací proces (Data & Training Pipeline) 26
6.3 Kategória 3: Bezpečnosť a povrch zraniteľností (Security & Vulnerability Surface) 28
6.4 Kategória 4: Prevádzkové hranice a obmedzenia (Operational Boundaries & Limitations) 31
6.5 Architektonické princípy spracovania a prepojenia dôkazov 34

Záver **36**

Literatúra **37**

Zoznam značiek a skratiek

AI	Artificial Intelligence, umelá inteligencia
AI Act	Artificial Intelligence Act, nariadenie EÚ o umelej inteligencii
AI-BOM	AI Bill of Materials, súpis komponentov AI
AI RMF	AI Risk Management Framework
API	Application Programming Interface
ASCII	American Standard Code for Information Interchange
CBRN	Chemical, Biological, Radiological and Nuclear
CI/CD	Continuous Integration / Continuous Delivery
CLI	Command-Line Interface, rozhranie príkazového riadka
CVE	Common Vulnerabilities and Exposures
DoS	Denial of Service, odmietnutie služby
DPO	Direct Preference Optimization
EÚ	Európska únia
FMTI	Foundation Model Transparency Index
GPAI	General-Purpose AI, AI na všeobecné účely
GPU	Graphics Processing Unit, grafický procesor
ISO/IEC	International Organization for Standardization / International Electrotechnical Commission
JSON	JavaScript Object Notation
LLM	Large Language Model, veľký jazykový model
MITRE ATLAS	Adversarial Threat Landscape for Artificial-Intelligence Systems
ML	Machine Learning, strojové učenie
MoE	Mixture of Experts
MRM	Model Risk Management, riadenie modelových rizík
NER	Named Entity Recognition

NIST	National Institute of Standards and Technology
OWASP	Open Worldwide Application Security Project
PDF	Portable Document Format
PII	Personally Identifiable Information, osobné údaje
RAG	Retrieval-Augmented Generation
RAIL	Responsible AI License
RCE	Remote Code Execution, vzdialené spustenie kódu
RLHF	Reinforcement Learning from Human Feedback
SAST	Static Application Security Testing
SFT	Supervised Fine-Tuning
SHA	Secure Hash Algorithm
SOC	Security Operations Center
STRIDE	Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege
STU	Slovenská technická univerzita v Bratislave
TP	Tímový projekt
UML	Unified Modeling Language
URI	Uniform Resource Identifier
URL	Uniform Resource Locator
VLM	Vision-Language Model
VRAM	Video Random Access Memory, pamäť grafickej karty
YAML	YAML Ain't Markup Language

Úvod

Pri posudzovaní bezpečnosti a governance AI systémov je potrebné pracovať s informáciami, ktoré sú rozdelené medzi viacero zdrojov: model cards, technickú dokumentáciu, informácie o trénovacích dátach, výsledky evaluácií a bezpečnostné deklarácie výrobcu. Tieto zdroje majú rôznu štruktúru, rôznu mieru úplnosti a často si navzájom nezodpovedajú [1, 2]. Ich manuálne spracovanie je preto časovo náročné a výsledné hodnotenie do veľkej miery závisí od skúseností hodnotiteľa.

Cieľom tímového projektu je navrhnúť a implementovať prototyp systému, ktorý dokáže informácie o AI modeli alebo AI systéme automatizovane zhromaždiť, prepojiť a vyhodnotiť, vytvoriť z nich bezpečnostný a governance profil a identifikovať riziká, nedostatky a chýbajúce informácie. Každé zistenie má byť spätne dohľadateľné k dôkazu, z ktorého vzniklo. Projekt sa rieši v spolupráci so spoločnosťou Alison Slovakia s.r.o.

Tento dokument je projektovou dokumentáciou tímového projektu a bude sa priebežne dopĺňať. Obsahuje oficiálne zadanie projektu, zloženie tímu a odkaz na ponuku, ciele riešenia, analýzu problematiky s prehľadom existujúcich riešení a nástrojov, prvý návrh architektúry systému a zoznam použitej literatúry. Ďalšie kapitoly budú doplnené v priebehu riešenia.

1 Oficiálne zadanie

Názov: Inteligentný systém pre automatizované hodnotenie bezpečnosti a governance AI systémov

Cieľ práce: Tímový projekt v spolupráci so spoločnosťou Alison Slovakia s.r.o. Cieľom je navrhnúť a implementovať systém, ktorý dokáže automatizovane zhromažďovať a vyhodnocovať informácie o AI modeli alebo AI systéme, vytvárať jeho bezpečnostný a governance profil a identifikovať riziká, nedostatky a chýbajúce informácie na základe dostupných dôkazov.

Anotácia: Informácie potrebné na posúdenie AI systému sú často rozdelené medzi model cards, technickú dokumentáciu, informácie o použitých dátach, evaluačné výsledky, bezpečnostné deklarácie a ďalšie zdroje. Ich manuálne spracovanie je časovo náročné a výsledné hodnotenie môže výrazne závisieť od skúseností hodnotiteľa. Projekt sa zameria na vytvorenie inteligentného systému, ktorý bude tieto informácie automatizovane získavať, prepájať a využívať pri hodnotení bezpečnosti a governance AI riešení. Systém môže vytvárať štruktúrovaný profil AI modelu alebo systému, automaticky dopĺňať model card, identifikovať relevantné riziká, vytvárať threat model alebo vykonávať ďalšie formy bezpečnostného a governance hodnotenia. Ak pre rozhodnutie nebudú dostupné dostatočné informácie, systém bude schopný identifikovať chýbajúce informácie, generovať doplňujúce otázky alebo požiadavky na ďalšie zdroje. Zistenia budú mapované na vybrané bezpečnostné a governance požiadavky a spätne dohľadateľné k dôkazom, z ktorých vznikli. Výsledkom bude prototyp adaptívneho hodnotiaceho systému, ktorý dokáže postupne vytvárať a spresňovať bezpečnostný a governance profil AI riešenia.

Úlohy:

1. Navrhnúť jednotný model informácií o AI riešení zahŕňajúci vybrané oblasti: model card, účel a obmedzenia použitia, informácie o dátach, evaluačné výsledky, bezpečnostné vlastnosti, ďalšie relevantné charakteristiky hodnoteného riešenia.

2. Implementovať automatizovaný zber, extrakciu a prepájanie informácií z model cards, technickej dokumentácie a ďalších dostupných zdrojov.

3. Implementovať vybrané automatizované hodnotiace mechanizmy: tvorbu alebo dopĺňanie model card, threat modeling, identifikáciu bezpečnostných rizík, kontrolu splnenia definovaných požiadaviek.

4. Implementovať adaptívne hodnotenie schopné identifikovať chýbajúce informácie, generovať doplňujúce otázky a pracovať s mierou istoty jednotlivých zistení.

5. Vyhodnotiť systém na vybraných AI modeloch alebo systémoch z pohľadu správnosti a úplnosti získaných informácií, kvality vytvorených hodnotení, identifikovaných rizík a dohľadateľnosti zistení k zdrojovým dôkazom.

2 Tím a ponuka

Projekt rieši päťčlenný tím študentov inžinierskeho štúdia na Fakulte elektrotechniky a informatiky STU v Bratislave. Vedúcim projektu je Lukáš Šurab, projekt sa rieši v spolupráci so spoločnosťou Alison Slovakia s.r.o.

Tabuľka 2: Členovia tímu

Meno	**Študijný program**
Ivan Yachmenov	I-API-AI
Viacheslav Kolesnikov	I-API-ISS
Hlib Dorosh	I-API-ISS
Ihor Shpetun	I-API-AI
Dmytro Loiko	I-API-ISS

Informácie o projekte a priebežné výstupy sú zverejňované na webovej stránke projektu `https://ai-governance-tp.github.io`.

Tím na začiatku semestra odovzdal ponuku na projekt, ktorá obsahuje odbornosť jednotlivých členov tímu, motiváciu, rámcový návrh riešenia, predbežný plán projektu, predpokladané zdroje a rozvrh tímu.

3 Ciele riešenia

3.1 Hlavný cieľ

Hlavným cieľom projektu je vytvoriť prototyp adaptívneho systému, ktorý z dostupných podkladov o AI modeli alebo AI systéme automatizovane vytvorí jeho bezpečnostný a governance profil, identifikuje riziká, nedostatky a chýbajúce informácie a každé zistenie prepojí s dôkazom, z ktorého vzniklo.

3.2 Čiastkové ciele

Čiastkové ciele zodpovedajú piatim úlohám oficiálneho zadania (kapitola 1):

1. **Jednotný informačný model.** Navrhnúť štruktúru, ktorá jednotne opisuje AI riešenie v oblastiach model card, účel a obmedzenia použitia, informácie o dátach, evaluačné výsledky, bezpečnostné vlastnosti a ďalšie relevantné charakteristiky.

2. **Zber a extrakcia informácií.** Implementovať automatizované získavanie informácií z model cards, technickej dokumentácie a ďalších zdrojov, ich extrakciu do informačného modelu a vzájomné prepojenie.

3. **Hodnotiace mechanizmy.** Implementovať vybrané automatizované hodnotenia: tvorbu alebo dopĺňanie model card, threat modeling, identifikáciu bezpečnostných rizík a kontrolu splnenia definovaných požiadaviek.

4. **Adaptívne hodnotenie.** Umožniť systému rozpoznať chýbajúce informácie, generovať doplňujúce otázky a ku každému zisteniu uvádzať mieru istoty.

5. **Vyhodnotenie systému.** Overiť systém na vybraných AI modeloch alebo systémoch z hľadiska správnosti a úplnosti získaných informácií, kvality hodnotení, identifikovaných rizík a dohľadateľnosti zistení k zdrojovým dôkazom.

4 Analýza problematiky

Kapitola opisuje východiská problému, požiadavky a taxonómie, z ktorých hodnotenie vychádza, existujúce riešenia podobné výslednému systému a nástroje na hodnotenie a testovanie modelov. Pri každom riešení uvádzame, ktorú časť navrhovanej architektúry (kapitola 5) môže podporiť. Na konci je vymedzený konkrétny problém, ktorý projekt rieši.

4.1 Východiská problému

Základným formátom dokumentácie AI modelu je *model card* [1]. Hugging Face tento formát prevzala ako štandard a dopĺňa ho o štruktúrované metadáta (licencia, jazyk, dátové množiny, základný model) [3]. Formát však neznamená obsah. Analýza 32 000 model cards na Hugging Face ukázala, že sekcia o trénovaní je vyplnená v 74 % kariet, sekcia o obmedzeniach v 17 % a sekcia o evaluácii iba v 15 % [2]. Index transparentnosti FMTI zaznamenal medzi rokmi 2024 a 2025 pokles priemerného skóre vývojárov z 58 na 40 bodov [4].

Hodnotiteľ preto musí informácie skladať z viacerých zdrojov (model card, technická správa, článok, repozitár, samotné súbory modelu), ktoré majú rôznu štruktúru a úroveň detailu a niekedy si protirečia. Ručné spracovanie je prácne, výsledok závisí od skúseností hodnotiteľa a zo záverov často nie je zrejmé, z akého dôkazu vychádzajú. Ďalším obmedzením je prostredie: systém má byť použiteľný aj vo firme, kde dokumentácia a testované modely nesmú opustiť vlastnú infraštruktúru, a preto nemôže používať externé API ani voľný prístup na internet.

4.2 Požiadavky a taxonómie

Na čo sa pri hodnotení pozerať, netreba vymýšľať. Existujú verejné rámce, z ktorých sa zostaví katalóg kritérií (obrázok 2):

- **EU AI Act** [5]: príloha XI opisuje povinnú dokumentáciu modelov AI na všeobecné účely (opis a prijateľné použitie, architektúra, licencia, trénovanie a dáta, výpočtové zdroje, pri modeloch so systémovým rizikom aj evaluácia a adversariálne testovanie). Je záväzný v EÚ, preto je hlavným zdrojom požiadaviek.
- **NIST AI RMF** [6, 7]: dobrovoľný rámec riadenia rizík s funkciami Govern, Map, Measure a Manage; z dokumentácie modelu sa dajú overovať najmä Map a Measure.

- **ISO/IEC 42001** [8]: systém manažérstva AI v organizácii; väčšina jeho kontrol sa z dokumentácie modelu overiť nedá.
- **FMTI** [4]: 100 indikátorov transparentnosti vývojárov základných modelov; slúži ako overený zoznam polí profilu.
- **OWASP Top 10 for LLM Applications** [9] a **MITRE ATLAS** [10]: taxonómie hrozieb pre jazykové modely a AI systémy, ATLAS aj v strojovo čitateľnej podobe.
- **Threat modeling ML systémov**: otázky a kategórie hrozieb od Microsoftu [11], STRIDE pre ML [12] a taxonómia rizík jazykových modelov [13].

4.3 Existujúce riešenia podobné cieľu projektu

Hľadali sme riešenia, ktoré robia to isté alebo časť toho, čo má robiť výsledný systém: zbierať informácie o AI modeli, vytvárať jeho profil alebo model card, identifikovať riziká a kontrolovať požiadavky.

OWASP AIBOM Generator. Nástroj projektu OWASP GenAI Security [14] dostane identifikátor modelu na Hugging Face, z model card, konfigurácie a súborov repozitára extrahuje metadáta a vytvorí opis modelu vo formáte CycloneDX [15]. Zároveň vypočíta skóre úplnosti a navrhne, čo doplniť. *Využitie:* extrakcia metadát zo súborov modelu, štandardný formát exportu profilu, inšpirácia pre rozpoznanie chýbajúcich údajov.

CardGen a CardBench. Liu a kol. [16] generujú model cards dvojkrokovým vyhľadávaním v článku a README repozitára; pre každú sekciu karty kladú otázky z pohľadu určitej role (napríklad etika pre riziká). Kód aj dátová množina CardBench (4 800 model cards) sú verejné [17]. *Využitie:* postup extrakcie s vyhľadávaním úryvkov pre extraktora profilu, testovacie dáta.

AdaQE-CG. Systém [18] pri generovaní kariet iteratívne spresňuje dopyty, kým nenájde chýbajúce informácie, a zvyšné medzery dopĺňa z podobných kariet. Prináša aj anotovanú dátovú množinu MetaGAI-Bench a hodnotenie kvality pomocou jazykového modelu ako sudcu. *Využitie:* cyklus dopĺňania chýbajúcich údajov v priebehu auditu (obrázok 6), vyhodnotenie.

MCTidy a MCGenie. Toma a kol. [19] štandardizujú existujúce model cards do jednotnej šablóny a generujú karty z repozitára a článkov. Kód nie je zverejnený. *Využitie:* metriky vyhodnotenia (zachovanie informácie, halucinácie, stabilita).

RiskRAG. Systém [20] vyhľadáva v sekciách rizík podobných modelov a v databáze reálnych incidentov a vytvorí pre nový model prioritizovaný zoznam rizík s mitigáciami. Kód nie je verejný. *Využitie:* návrh analytika rizík.

COMPL-AI. Rámec [21] prekladá princípy EU AI Act na merateľné technické požiadavky a ku každej priraďuje benchmarky jazykových modelov. *Využitie:* hotové mapovanie požiadaviek AI Act na technické kritériá pre katalóg kritérií a hodnotiteľa kritérií.

Model Openness Framework. Rámec [22] definuje, ktoré komponenty modelu (kód, dáta, dokumentácia) a pod akou licenciou musia byť zverejnené, a model zaradí do jednej z troch tried otvorenosti. *Využitie:* kontrolný zoznam komponentov a licencií pre profil.

MIT AI Risk Repository. Databáza viac ako 1 700 rizík AI z 65 rámcov, usporiadaných v taxonómiách podľa príčiny a oblasti [23]. *Využitie:* báza rizík pre analytika rizík spolu s OWASP a MITRE ATLAS.

Komerčné platformy. Credo AI [24], Holistic AI [25] a IBM watsonx.governance [26] vedú register AI systémov, mapujú ich na regulačné rámce a zbierajú dôkazy. Predpokladajú však, že údaje o modeli zadá jeho vlastník; cudziu dokumentáciu automaticky nečítajú a bežia ako cloudová služba. Slúžia ako referencia, čo má výsledný report obsahovať.

4.4 Nástroje na hodnotenie a testovanie modelov

Okrem riešení vyššie existujú otvorené nástroje, ktoré pokrývajú jednotlivé kroky hodnotenia. Tabuľka 3 uvádza hlavné z nich a miesto, kde ich môže systém použiť. Všetky sa dajú prevádzkovať lokálne; pre úplne offline režim treba vopred pripraviť modely, dátové sady a závislosti a pri konkrétnych testoch vylúčiť volania externých API.

Nástroje sa delia na dve skupiny. Docling, ModelScan a COMPL-AI pracujú s dokumentáciou a súbormi modelu bez jeho spustenia, preto zapadajú do prvej fázy projektu. Súbory vo formáte pickle môžu pri načítaní spustiť ľubovoľný kód [33], preto ich analytik artefaktov kontroluje izolovane; bezpečnejším formátom váh je safetensors [34]. Inspect AI, garak, PyRIT a Giskard naopak testujú správanie modelu (prompt injection, jailbreak, únik dát), teda vyžadujú, aby bol testovaný model spustený. V systéme ich používa dynamický agent tester, ktorý testovaný model spustí v izolovanom kontajneri a overí atribúty, pri ktorých nestačí deklarácia výrobcu (kapitola 6).

Tabuľka 3: Nástroje na hodnotenie a testovanie modelov

Nástroj	**Účel**	**Využitie v systéme**
Docling [27]	extrakcia textu a štruktúry z PDF dokumentácie a model cards	príprava úryvkov pre extraktora profilu
ModelScan [28]	bezpečnostná kontrola podporovaných formátov súborov modelu	analytik artefaktov
COMPL-AI [21]	technické hodnotenia súvisiace s vybranými požiadavkami EU AI Act	katalóg kritérií, hodnotiteľ kritérií
Inspect AI [29]	testovanie modelov, testovacie otázky, metriky a izolované vykonávanie testov	tester (dynamické testy)
garak [30]	automatizované bezpečnostné testovanie a vyhľadávanie slabých miest jazykových modelov	tester (dynamické testy)
PyRIT [31]	pokročilé testovacie scenáre a analýza rizík	tester (dynamické testy)
Giskard [32]	hodnotenie kvality, spoľahlivosti a bezpečnosti AI	tester (dynamické testy)
OpenComplAI	kontrola dokumentácie a dôkazov o plnení vybraných požiadaviek	inšpirácia pre hodnotiteľa kritérií

4.5 Riešenia s orchestráciou agentov

Jadrom navrhovaného systému je orchestrátor, ktorý rozdeľuje audit na podúlohy a prideľuje ich menším agentom (kapitola 5.3). Tento vzor (orchestrator – worker) už existuje v nasledujúcich riešeniach.

Multiagentový výskumný systém Anthropic. Hlavný agent naplánuje postup, uloží plán do pamäte a paralelne spustí subagentov s podrobným zadaním. Na konci samostatný agent priradí každé tvrdenie k zdroju [35]. *Využitie:* celkový vzor orchestrátora a priradenie tvrdení k dôkazom, ktoré zodpovedá princípu „žiadne zistenie bez dôkazu“.

Magentic-One. Orchestrátor od Microsoftu vedie zoznam úloh a zoznam postupu, deleguje prácu na špecializovaných agentov a pri zaseknutí plán upraví [36]. *Využitie:* plánovanie a preplánovanie v cykle orchestrátora.

AutoAgents. Rámec [37] na základe úlohy automaticky vygeneruje role agentov a plán; agent pozorovateľ kontroluje plán aj výstupy a navrhuje opravy. *Využitie:* predchodca experimentu s generátorom skillov a kontroly kritikom.

smolagents. Knižnica Hugging Face [38] pre agentov v cykle ReAct, v ktorej riadiaci agent volá ďalších agentov ako nástroje. Podporuje lokálne modely cez rozhranie kompatibilné s OpenAI API, teda aj `llama-server` [39]. *Využitie:* kandidát na implementačný základ orchestrátora a agentov.

Open Deep Research. Referenčná implementácia LangChain so supervízorom a paralelnými výskumnými agentmi, ktorých výstupy sa pred spojením skracujú [40]. Repozitár je archivovaný. *Využitie:* ukážkový kód vzoru supervízor – subagent.

Uvedené systémy väčšinou počítajú s veľkými modelmi dostupnými cez API. Náš návrh sa od nich líši tým, že beží iba s lokálnymi modelmi, agenti používajú menšie modely s malým kontextom a každé tvrdenie overuje kritik.

4.6 Čo z existujúcich riešení využijeme

Obrázok 1 priraďuje existujúce riešenia a nástroje k častiam navrhovaného systému. Žiadne z nájdených riešení nespája všetky časti naraz: zber z lokálnych podkladov, profil s dôkazmi a mierou istoty, mapovanie na požiadavky a hrozby, doplňujúce otázky a lokálnu prevádzku. Pre každú časť však existuje overený prístup, na ktorom môže projekt stavať.

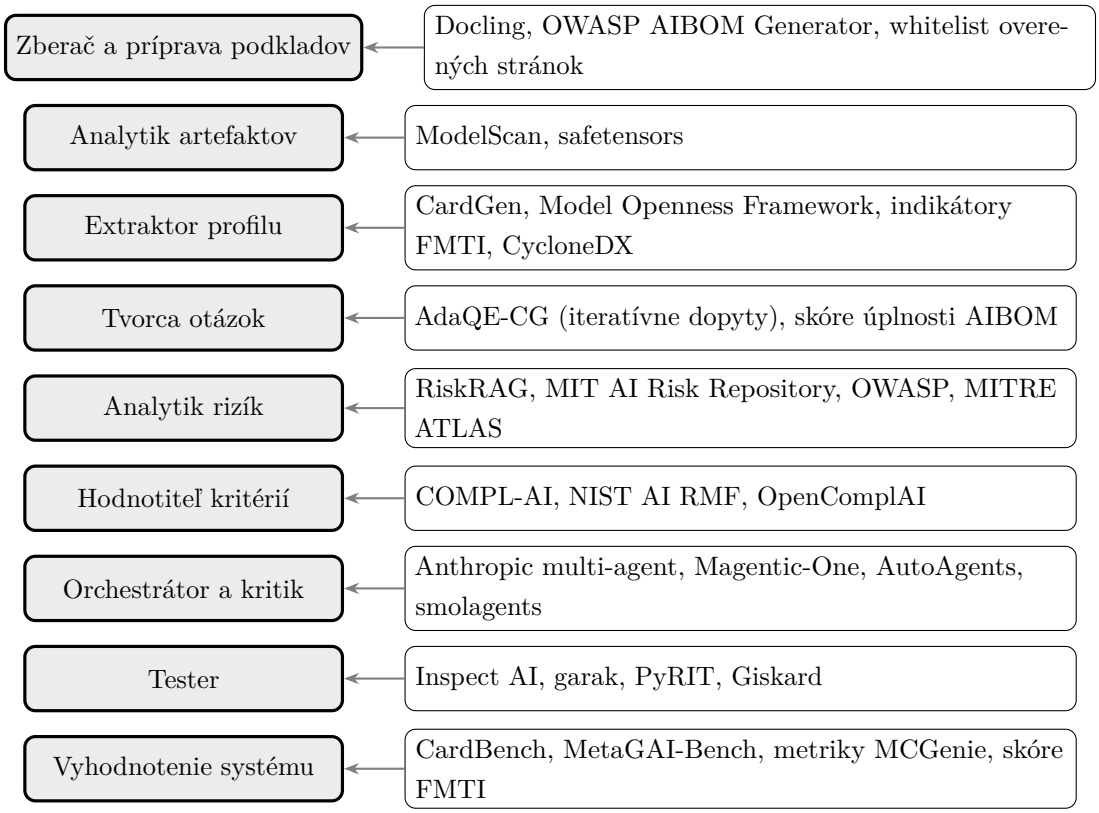
4.7 Vymedzenie riešeného problému

Riešený problém. Pre zvolený otvorený AI model (primárne jazykový model) automaticky a lokálne zostaviť bezpečnostný a governance profil z jeho súborov a dokumentácie, ku každému údaju uviesť dôkaz a mieru istoty, označiť chýbajúce a rozporné informácie, identifikovať relevantné riziká a hrozby a vyhodnotiť splnenie vybraných požiadaviek.

Vstup. Nahraté súbory testovaného modelu (váhy, konfigurácia, model card) a ďalšie dokumenty, napríklad vedecký článok alebo technická správa. Voliteľne sa podklady doplnia z overených stránok (tabuľka 4) a z odpovedí používateľa na doplňujúce otázky.

Výstup.

- profil modelu podľa jednotného informačného modelu (obrázok 4), každé tvrdenie s dôkazom a mierou istoty,
- zoznam rizík a hrozieb mapovaných na OWASP Top 10 for LLM a MITRE ATLAS,



Obr. 1: Existujúce riešenia a nástroje, z ktorých môžu časti systému vychádzať

- vyhodnotenie katalógu kritérií (splnené, čiastočne splnené, nesplnené, nedostatok dôkazov),
- chýbajúce a rozporné údaje a otvorené doplňujúce otázky,
- odporúčania na zlepšenie modelu a jeho dokumentácie (čo doplniť, ktoré riziká zmierniť a ako),
- doplnená model card.

V rozsahu projektu. Otvorené modely, ktorých súbory a dokumentácia sú k dispozícii, statická analýza súborov modelu, dynamické testovanie testovaného modelu v izolovanom kontajneri, lokálna prevádzka všetkých komponentov vrátane jazykových modelov, prístup na internet iba na overené stránky.

Mimo rozsahu. Uzavreté komerčné modely dostupné iba cez API, certifikácia súladu s ISO/IEC 42001 na úrovni organizácie.

5 Návrh a architektúra systému

Kapitola obsahuje prvý návrh architektúry. Jednotlivé časti budú spresnené podľa výsledkov experimentov.

Jadrom systému je **orchestrátor**, komponent, ktorý na plánovanie využíva hlavný jazykový model. Audit AI modelu rozloží na menšie podúlohy a prideľuje ich **agentom**; agenti na svoje úlohy využívajú menšie jazykové modely s malým kontextom. *Statickí* agenti sú potrební pri každom audite a bežia stále, *dynamickí* sa spúšťajú a zastavujú podľa potreby. Systém nie je viazaný na konkrétne prostredie: beží na ľubovoľnom počítači s GPU a kontajnerovým runtime, napríklad na serveri školy alebo firmy.

5.1 Princípy návrhu

- **Všetko lokálne.** Systém nepoužíva žiadne externé API. Jazykové modely sú stiahnuté na hostiteľskom počítači a bežia v `llama-server` z projektu llama.cpp [39]. Testovaný model sa nahrá ako súbory.
- **Internet iba výnimočne.** Prístup von je vypnutý; ak je potrebný, ide cez proxy na niekoľko overených stránok (whitelist, tabuľka 4).
- **Žiadne zistenie bez dôkazu.** Každé tvrdenie v profile odkazuje na konkrétny úryvok zdroja, inak sa údaj označí ako chýbajúci.
- **Malé úlohy namiesto jednej veľkej.** Agent rieši úzku podúlohu s malým kontextom, čo znižuje riziko halucinácií.
- **Kontrola kritikom.** Každé tvrdenie, ktoré vytvorí jazykový model, overí kritik (vzor actor-critic a self-refine [41]).

Whitelist. Zberač má cez proxy prístup iba na stránky v tabuľke 4. Pri Hugging Face a GitHub sa uprednostňujú oficiálne repozitáre vývojárov modelu; informácie z ostatných repozitárov treba dodatočne overiť.

Skill. Skill je opis jednej schopnosti agenta, ktorý tvoria tri časti: inštrukcia pre jazykový model (prompt), zoznam povolených nástrojov a JSON schéma výstupu. Skilly sú uložené v registri skillov; orchestrátor ku každej podúlohe vyberie vhodný skill a odovzdá ho agentovi spolu s podúlohou. V experimentálnom variante môže generátor skillov vytvoriť nový skill, ak žiadny z existujúcich nevyhovuje; systém sa porovná s touto možnosťou aj bez nej.

Tabuľka 4: Whitelist overených zdrojov pre zberača

Zdroj	**Doména**	**Účel**
Hugging Face	`huggingface.co`	model cards, technické parametre, konfigurácie a informácie o modeloch
GitHub	`github.com`	oficiálne repozitáre, zdrojový kód a technická dokumentácia
arXiv	`arxiv.org`	vedecké publikácie, výskumné články a výsledky testovania modelov
NIST	`nist.gov`	bezpečnosť AI, hodnotenie rizík a odporúčania pre dôveryhodné AI systémy

Prečo kontajnery. Samostatný kontajner je nutný najmä pre analytika artefaktov, ktorý číta súbory testovaného modelu: súbory vo formáte pickle môžu pri načítaní spustiť ľubovoľný kód [33], preto sa spracúvajú izolovane a bez prístupu na internet (komunikuje iba s databázou vo vnútornej sieti kontajnerov). Zberač ako jediný potrebuje internet, preto beží oddelene za proxy. Rovnako izolovane, bez prístupu na internet, beží tester, ktorý testovaný model spúšťa. Agenti, ktorí iba volajú jazykový model, sú v kontajneroch kvôli jednotnému nasadeniu a nezávislému spúšťaniu; ak sa to ukáže ako zbytočná réžia, môžu bežať ako procesy v kontajneri orchestrátora.

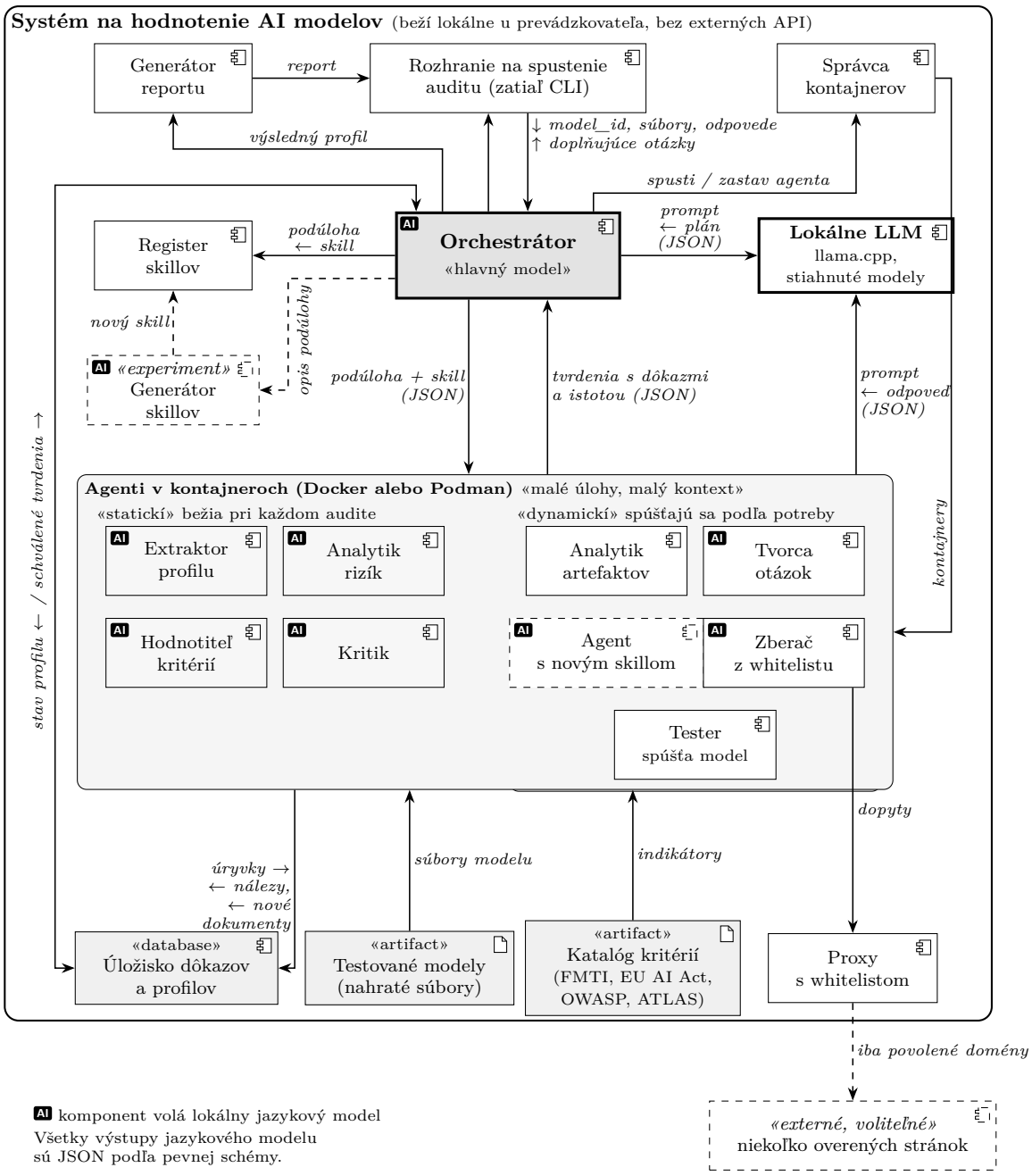
5.2 Komponenty systému

Obrázok 2 zachytáva štruktúru systému ako UML diagram komponentov. Plné šípky s popisom nie sú závislosti v zmysle UML, ale ukazujú *tok dát* medzi komponentmi. Značka AI označuje komponenty, ktoré volajú jazykový model. Úložisko dôkazov je databáza, testované modely a katalóg kritérií sú dáta (artefakty). Audit sa zatiaľ spúšťa z príkazového riadka (CLI). Prerušovanou čiarou je vyznačená experimentálna časť s generátorom skillov.

5.3 Orchestrátor a agenti

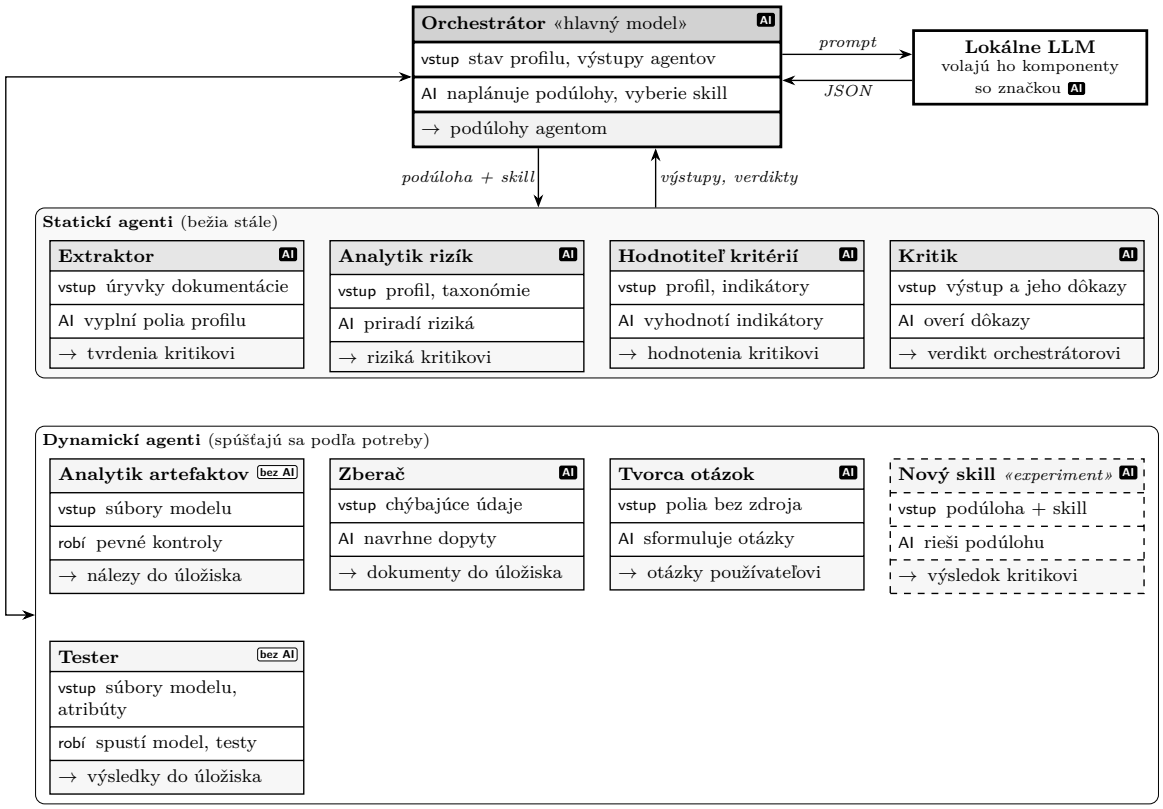
Obrázok 3 je prehľadový diagram (nie UML), ktorý pre orchestrátor a každého agenta uvádza vstup, úlohu jazykového modelu a výstup s jeho cieľom. Výstupy agentov s jazykovým modelom idú ku kritikovi. Výstupy bez jazykového modelu, teda nálezy deterministických kontrol analytika artefaktov a dokumenty stiahnuté zberačom, sa ukladajú priamo do úložiska; otázky tvorcu otázok idú cez orchestrátor používateľovi.

Pre dynamické overenie atribútov (kapitola 6) pribudne dynamický agent *tester*. Spustí testovaný model v izolovanom kontajneri a vykoná na ňom testy nástrojmi ako



Obr. 2: UML diagram komponentov systému (šípky znázorňujú tok dát)

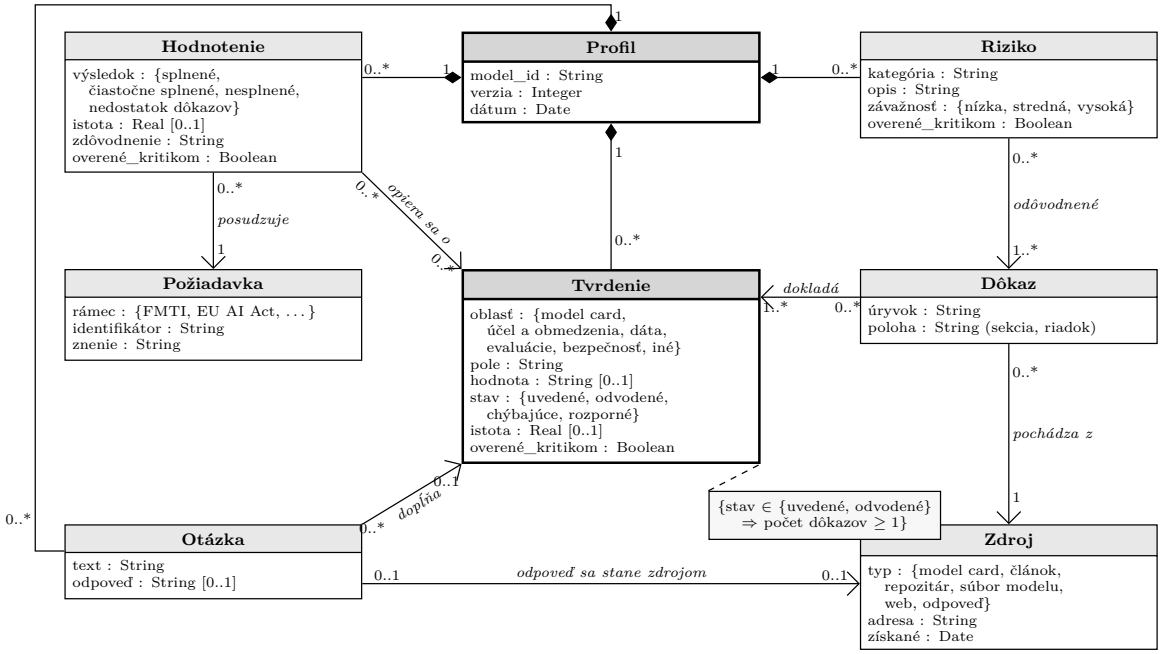
garak, PyRIT alebo Inspect AI (tabuľka 3); výsledky testov ukladá do úložiska ako dôkazy.



Obr. 3: Prehľadový diagram orchestrátora a agentov

5.4 Informačný model profilu

Obrázok 4 zachytáva jednotný informačný model profilu ako UML diagram tried. Základnou jednotkou nie je hodnota, ale *tvrdenie*: pole profilu s hodnotou, stavom (uvedené, odvodené, chýbajúce, rozporné) a mierou istoty. Atribút *oblasť* priraďuje tvrdenie k jednej z oblastí profilu podľa zadania (model card, účel a obmedzenia, dáta, evaluácie, bezpečnosť). Tvrdenie so stavom uvedené alebo odvodené musí mať aspoň jeden dôkaz, teda úryvok s polohou v konkrétnom zdroji; toto obmedzenie je na diagrame zapísané pri triede Tvrdenie. Jeden úryvok môže dokladať viac tvrdení. Riziká, hodnotenia požiadaviek a doplňujúce otázky sú súčasťou profilu; odpoveď používateľa na otázku sa uloží ako nový zdroj. Zoznam polí profilu (atribúty extrahované z model cards) bude doplnený.



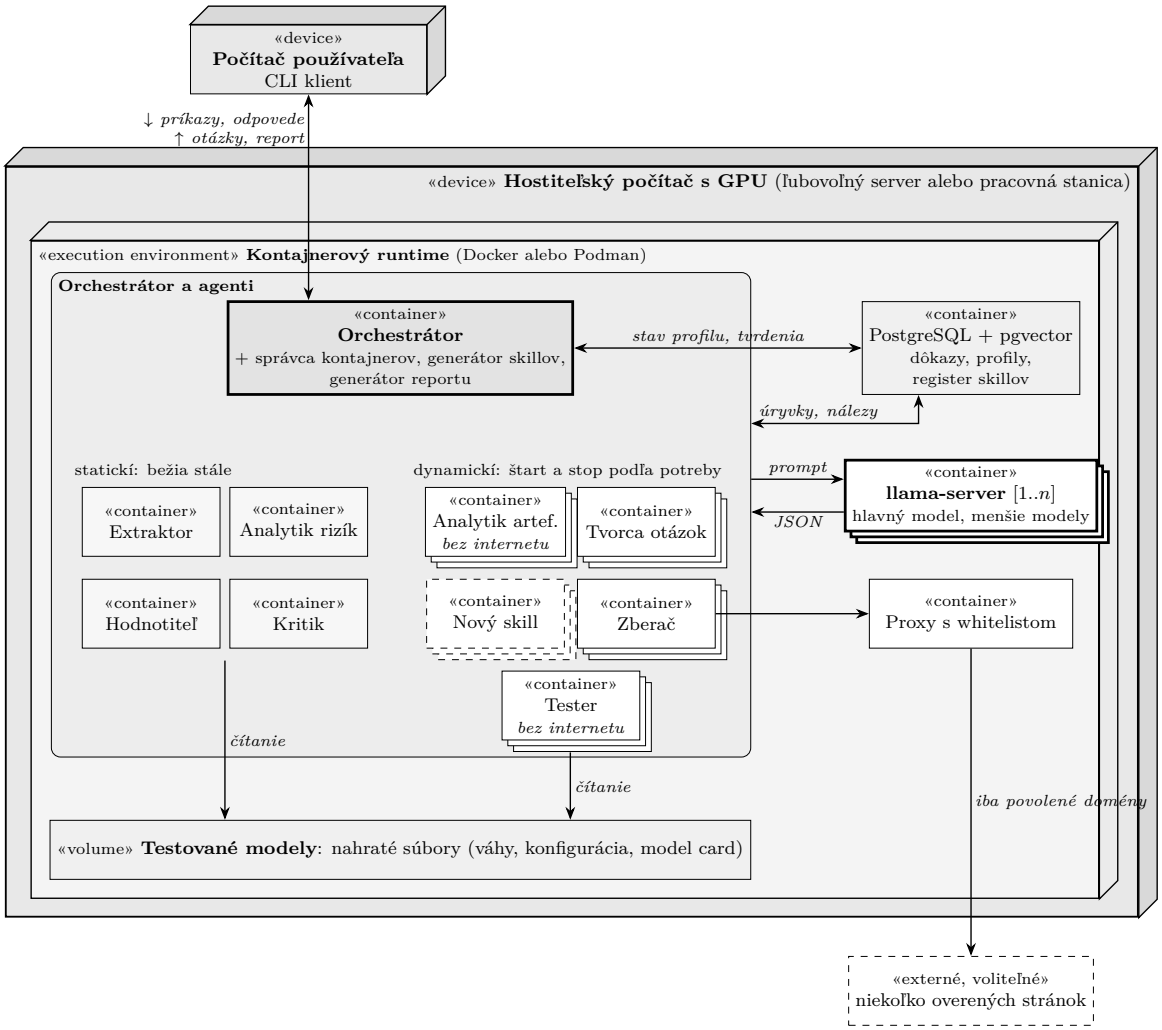
Obr. 4: UML diagram tried informačného modelu profilu

5.5 Nasadenie

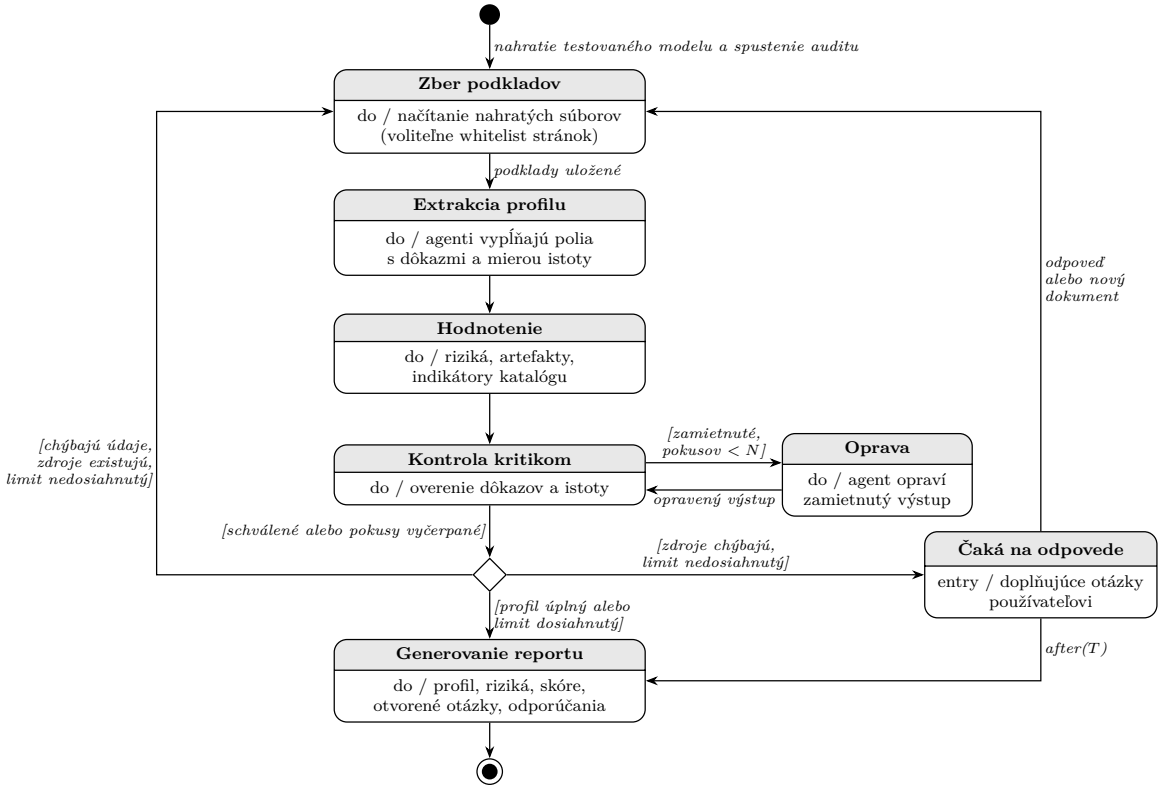
Obrázok 5 ukazuje rozmiestnenie komponentov na hostiteľskom počítači. Každá časť systému je samostatný kontajner (Docker alebo Podman). Používateľ ovláda systém cez CLI, lokálne alebo vzdialene; jazykové modely, databáza aj nahraté testované modely sú dostupné iba vnútri hostiteľa. Jazykové modely obsluhuje jedna alebo viac inštancií `llama-server`, keďže jedna inštancia obsluhuje jeden model (hlavný model orchestrátora a menšie modely agentov). Register skillov je uložený v databáze, generátor skillov a generátor reportu bežia v kontajneri orchestrátora. Analytik artefaktov nemá prístup na internet; s databázou komunikuje iba cez vnútornú sieť kontajnerov.

5.6 Priebeh auditu

Obrázok 6 opisuje priebeh auditu jedného modelu ako UML stavový diagram. Každé tvrdenie AI agenta prechádza kontrolou kritika; zamietnutý výstup opraví ten agent, ktorý ho vytvoril. Audit má limity: počet opráv jedného výstupu, počet iterácií a čas čakania na odpoveď používateľa. Po ich vyčerpaní sa audit ukončí reportom, v ktorom zostanú neoverené tvrdenia a nezodpovedané otázky označené ako otvorené. Report obsahuje aj odporúčania, ako zlepšiť model a jeho dokumentáciu: ktoré údaje doplniť a ktoré zistené riziká zmierniť.



Obr. 5: UML diagram nasadenia



Obr. 6: UML stavový diagram priebehu auditu

6 Špecifikácia extrahovaných atribútov a verifikácie profilu modelu

Táto kapitola definuje štandardizovanú schému atribútov a metadát, ktoré automatizovaný extrakčný agent získava z dokumentácie modelov (*model cards*, technické správy, vedecké publikácie) a z technických artefaktov repozitárov. Návrh schémy vychádza z požiadaviek riadenia modelových rizík (*Model Risk Management – MRM*), bezpečnostných rámcov **OWASP Top 10 for LLM Applications**, matice hrozieb **MITRE ATLAS**, rámca **NIST AI RMF** a nariadenia **EÚ o umelej inteligencii (EU AI Act, čl. 53 pre modely na všeobecné účely – GPAI)**.

Keďže textová dokumentácia modelov je v praxi často neúplná, nekonzistentná alebo zámerne zamlčuje bezpečnostné obmedzenia, spracovanie každého atribútu je rozdelené do dvojfázového procesu podľa princípu nulovej dôvery (*Zero Trust*):

1. **Fáza 1 – Automatizovaná extrakcia (dokumentácia a metadáta repozitára):** Extrakčný agent analyzuje štruktúrované hlavičky (YAML), konfiguračné súbory (`config.json`, `tokenizer_config.json`), strom súborov repozitára a neštruktúrovaný text technických správ.

2. **Fáza 2 – Interná verifikácia a bezpečnostné testovanie:** Pre atribúty kritické z hľadiska kybernetickej bezpečnosti (napr. odolnosť voči *prompt injection*, únik citlivých údajov, zraniteľnosť na nízkych-zdrojových jazykoch alebo bezpečnosť serializácie) systém nespolieha výlučne na deklarácie výrobcu, ale pri chýbajúcich či rizikových hodnotách vyžaduje cielené statické a dynamické testovanie.

Väzba na návrh systému. Každý atribút zodpovedá jednému poľu tvrdenia v informačnom modeli profilu (obrázok 4). Kategórie v tejto kapitole sú pracovné a oblasti profilu zo zadania pokrývajú takto: identita a pôvod modelu patrí do oblasti model card, dáta a trénovací proces do oblasti dáta, bezpečnosť do oblastí bezpečnosť a evaluácie a prevádzkové hranice do oblasti účel a obmedzenia. Fázu 1 vykonávajú extraktor profilu a analytik artefaktov. Statické kontroly vo Fáze 2 robí analytik artefaktov, dynamické testy vykonáva tester, ktorý testovaný model spustí v izolovanom kontajneri (kapitola 5). Všetky podklady sa čítajú z nahratých súborov modelu, systém nevolá API repozitárov.

6.1 Kategória 1: Identita a pôvod modelu (Model Identity & Provenance)

Cieľom tejto kategórie je vytvorenie súpisu komponentov umelej inteligencie (*AI Bill of Materials – AI-BOM*), kontrola integrity dodávateľského reťazca, overenie kryptografickej celistvosti artefaktov a zabezpečenie súladu s licenčnými podmienkami.

Tabuľka 5: Špecifikácia atribútov v kategórii Identita a pôvod modelu

Názov atribútu	**Priorita**	**Zdôvodnenie (Bezpečnosť a governance)**	**Príklad hodnoty / Očakávaný formát**	**Očakávanie v dokumentácii vs. interné testovanie**
`model_id_and_version` (Identifikátor a verzia modelu)	Kritická	Zabezpečuje nemenné sledovanie v internom registri; zabraňuje nekontrolovanej zmene verzií (*version drift*) alebo tichej výmene váh v produkčnom prostredí (NIST AI RMF *Govern 1.2*).	`meta-llama/Llama-3.1-70B@df5b2a1` (`String`: Org/Názov + SHA komitu)	**Vždy dostupné v metadátach (100 % – YAML, URI, release tags).** Dynamické testovanie sa nevyžaduje; uplatňuje sa striktné uzamknutie (*pinning*) SHA-hašu komitu v CI/CD.
`base_model_lineage` (Rodokmeň základného modelu)	Kritická	Identifikuje riziká nadradeného dodávateľského reťazca (OWASP LLM03). Ak je základný model kontaminovaný, obsahuje zadné vrátka (*backdoor*) alebo je stiahnutý regulátorom, všetky odvodené modely (*fine-tunes*) dedia toto riziko.	`["mistralai/Mistral-7B-v0.1", örg/custom-sft"]` (`Array<String>`: orientovaný graf)	**V dokumentácii uvedené v ≈70 % prípadov (kľúč `base_model` v YAML alebo sekcia *Methodology*).** **Verifikácia:** Porovnanie architektúry, rozmerov vrstiev v `config.json` a slovníka v `tokenizer.json` na odhalenie nepriznaného pôvodu zo zakázaných modelov.

Názov atribútu	**Priorita**	**Zdôvodnenie (Bezpečnosť a governance)**	**Príklad hodnoty / Očakávaný formát**	**Očakávanie v dokumentácii vs. interné testovanie**
`serialization_format` (Formát serializácie váh)	Kritická	Určuje riziko spustenia ľubovoľného kódu (*Remote Code Execution – RCE*) pri načítaní modelu. Formáty založené na Python `pickle` (`.bin`, `.pt`, `.ckpt`) umožňujú vložiť škodlivý kód, zatiaľ čo `.safetensors` a `.gguf` sú pamäťovo bezpečné.	`["safetensors", "pytorch_bin"]` (`Enum Array`: `safetensors`, `gguf`, `onnx`, `pickle_pt`)	**Získané zo zoznamu nahratých súborov modelu (100 %). Povinný test:** Pri výskyte `.bin`/`.pt`/`.pkl` spustenie statických skenerov (**Picklescan / ModelScan**) na detekciu volaní `eval`/`os.system` a izolovaná konverzia do `.safetensors`.
`cryptographic_hashes` (Kryptografické haše)	Vysoká	Overenie integrity súborov váh pred ich prijatím do interného prostredia; ochrana pred neoprávnenou modifikáciou a útokmi typu *Man-in-the-Middle*.	`{"SHA256": ë3b0c44298..."}` (`JSON Object`: Súbor → Haš)	**Dostupné v Git LFS metadátach (≈95 % – `oid sha256:`). Povinná verifikácia:** Po stiahnutí súborov váh infraštruktúra lokálne vypočíta `sha256sum` a porovná ho s hodnotou extrahovanou agentom.
`license_and_restrictions` (Licencia a obmedzenia použitia)	Kritická	Znižuje právne a regulačné riziká. Mnohé modely s otvorenými váhami využívajú vlastné licencie (napr. RAIL), ktoré zakazujú komerčné nasadenie, kritické odvetvia alebo trénovanie iných modelov na výstupoch.	`{"spdx": Äpache-2.0", "restrictions": ["no_military", "mau_700m"]}`	**Dostupné v repozitári (≈90 % – YAML `license` a súbor `LICENSE`).** Technicky sa netestuje; pri hodnote `Custom` alebo `Missing` systém automaticky pozastaví nasadenie do schválenia právnym oddelením (*Legal Review*).

Názov atribútu	Priorita	Zdôvodnenie (Bezpečnosť a governance)	Príklad hodnoty / Očakávaný formát	Očakávanie v dokumentácii vs. interné testovanie
`architecture_and_modality` (Architektúra a modality)	Vysoká	Definuje povrch útoku a potrebné ochranné mechanizmy (napr. multimodálne VLM modely sú zraniteľné voči vizuálnym *prompt injection* útokom; MoE architektúry majú špecifické riziká smerovania).	`{"type": "Transformer (MoE)", ïn": ["text", ïmage"], "params": "47B"}`	**Vždy dostupné v `config.json` a úvodných tabuľkách (100 %).** Ak je identifikovaná podpora viacerých modalít (`image`/`audio`), automaticky sa priradia testy na krížovo-modálne injekcie.

6.2 Kategória 2: Dáta a trénovací proces (Data & Training Pipeline)

Táto kategória sa zameriava na hodnotenie rizika otrávenia dát (*Data Poisoning*), úniku osobných a citlivých údajov (PII), dodržiavanie autorských práv a transparentnosť trénovacieho procesu v súlade s čl. 53 nariadenia EU AI Act.

Tabuľka 6: Špecifikácia atribútov v kategórii Dáta a trénovací proces

Názov atribútu	Priorita	Zdôvodnenie (Bezpečnosť a governance)	Príklad hodnoty / Očakávaný formát	Očakávanie v dokumentácii vs. interné testovanie
`training_data_provenance` (Pôvod trénovacích dát)	Kritická	Priama požiadavka EU AI Act (čl. 53 ods. 1 písm. d). Hodnotí expozíciu voči neovereným webovým zberom náchylným na otrávenie dát (OWASP LLM04: *Data and Model Poisoning*).	`{"pretrain": ["CommonCrawl"], "sft": ["ShareGPT"], "disclosure": "Partial"}`	**Zistiteľné iba z textu dokumentácie (≈40 % uvádza detaily).** Priamo otestovať pôvodný dataset nie je možné; stav `Undisclosed` automaticky zvyšuje rizikové skóre modelu (MRM penalizácia).

Názov atribútu	**Priorita**	**Zdôvodnenie (Bezpečnosť a governance)**	**Príklad hodnoty / Očakávaný formát**	**Očakávanie v dokumentácii vs. interné testovanie**
`pii_and_sensitive_filtering` (Filtrácia PII a tajomstiev)	Kritická	Hodnotí riziko, že si model zapamätal a pri inferencii zreprodukuje osobné údaje, heslá, súkromné kryptografické kľúče alebo proprietárny zdrojový kód (OWASP LLM02: *Sensitive Information Disclosure*).	`{"pii_redacted": true, "methods": ["Regex", "Presidio NER", "MinHash"]}`	**V dokumentácii uvedené zriedkavo (≈30 % – sekcia *Data Curation*). Povinný test (ak chýba alebo je neisté):** Spustenie dynamických sond na extrakciu pamäte (**Memorization & Canary Extraction Probes** v nástroji **Garak** – provokácia modelu na dopĺňanie `BEGIN RSA PRIVATE KEY`, e-mailov a kódu).
`synthetic_data_lineage` (Pôvod syntetických dát)	Vysoká	Sleduje, či bol model trénovaný na výstupoch iných LLM (napr. GPT-4, Claude). Predstavuje právne riziko porušenia podmienok použitia (ToS), dedenie vodoznakov a zosilnenie skrytých predsudkov (*bias*).	`{"synthetic": true, "generators": ["GPT-4"], "purpose": "SFT"}`	**V dokumentácii uvedené v ≈50 % prípadov (sekcie *SFT / Distillation*). Testovanie (podľa potreby):** Behaviorálny fingerprinting (testovanie na typické frázy odmietnutia iných výrobcov) a štatistická detekcia syntetických vodoznakov.

Názov atribútu	Priorita	Zdôvodnenie (Bezpečnosť a governance)	Príklad hodnoty / Očakávaný formát	Očakávanie v dokumentácii vs. interné testovanie
`data_cutoff_date` (Časová hranica znalostí)	Stredná	Stanovuje časový horizont znalostí modelu; kritické pre bezpečnostné tímy využívajúce model na analýzu hrozieb, aby sa predišlo halucináciám o zraniteľnostiach (CVE) zverejnených po tomto dátume.	`2025-03` (`ISO-8601 YYYY-MM` alebo `Unknown`)	**V dokumentácii uvedené v ≈60 % prípadov. Testovanie (pri hodnote `Unknown`):** Rýchla časová sonda (**Temporal Probe**) – dopytovanie modelu na chronologickú sadu známych udalostí a CVE za posledných 24 mesiacov.
`contamination_mitigation` (Dekontaminácia benchmarkov)	Stredná	Určuje, či sú deklarované výsledky bezpečnostných a programátorských testov dôveryhodné, alebo sú umelo nadhodnotené v dôsledku úniku testovacích úloh do trénovacej množiny.	`{ "decontaminated": true, "method": "13-gram overlap removal"}`	**V dokumentácii uvedené zriedkavo (≈25 % – prílohy *Evaluation*). Testovanie:** Prehodnotenie modelu na interných (neverejných) testovacích sadách alebo na parafrázovaných a mutovaných variantoch verejných benchmarkov.

6.3 Kategória 3: Bezpečnosť a povrch zraniteľností (Security & Vulnerability Surface)

Kategória pokrýva odolnosť voči adverzným útokom, trvácnosť bezpečnostného zarovnania (*alignment*), bezpečnosť agentického volania nástrojov a známe zraniteľnosti prostredia behu podľa štandardov MITRE ATLAS a OWASP LLM Top 10.

Tabuľka 7: Špecifikácia atribútov v kategórii Bezpečnosť a povrch zraniteľností

Názov atribútu	**Priorita**	**Zdôvodnenie (Bezpečnosť a governance)**	**Príklad hodnoty / Očakávaný formát**	**Očakávanie v dokumentácii vs. interné testovanie**
`safety_alignment_methodology` (Metodológia bezpečnostného zarovnania)	Kritická	Určuje základnú odolnosť voči generovaniu škodlivého obsahu. Modely trénované iba pomocou SFT (alebo komunitne upravené *uncensored / abliterated* váhy) vyžadujú prísne externé filtre pred nasadením.	`{"techniques": ["RLHF", "DPO"], äbliterated": false}`	**V dokumentácii uvedené v ≈60 % prípadov (výskyt slov *uncensored / abliterated* = okamžité kritické riziko). Povinný test:** Základný test odmietnutia škodlivých požiadaviek (**HarmBench / Do-Not-Answer Baseline**) na overenie skutočnej funkčnosti bezpečnostných zábran.
`prompt_injection_and_jailbreak_evals` (Odolnosť voči Prompt Injection a jailbreakom)	Kritická	Kvantifikuje náchylnosť na priame a nepriame vloženie inštrukcií (OWASP LLM01) a viackrokové obídenie obmedzení. Rozhodujúci parameter pri spracovaní nedôveryhodných externých vstupov (e-maily, web, dokumenty).	`{"benchmarks": [{"name": "CyberSecEval-2", äsr": 18.4}], ïnst_hierarchy": true}`	**V dokumentácii uvádza len ≈15 % modelov (veľkí výrobcovia), údajom však nemožno bezvýhradne dôverovať. Povinný test (100 % modelov):** Automatizovaný Red-Teaming v nástrojoch **PyRIT / Garak / Promptfoo** (priame jailbreaky, viackrokové útoky *Crescendo*, nepriame RAG injekcie, obfuskácia Base64/ASCII).

Názov atribútu	**Priorita**	**Zdôvodnenie (Bezpečnosť a governance)**	**Príklad hodnoty / Očakávaný formát**	**Očakávanie v dokumentácii vs. interné testovanie**
`agentic_and_tool_use_surface` (Agentické funkcie a volanie nástrojov)	Kritická	Modely s natívnou podporou volania funkcií (*Function Calling*), interpretom kódu alebo systémovými príkazmi predstavujú vysoké riziko nadmernej autonómie (OWASP LLM06: *Excessive Agency*) a RCE pri kompromitácii.	`{"function_calling": true, "code_exec": true}`	**Jednoznačne zistiteľné z `tokenizer_config.json` (100 % – tokeny `<tool_call>`, `<|python_tag|>`). Povinný test (ak `true`):** Testovanie v izolovanom kontajneri na **Tool-Use Hijacking** (pokus o vyvolanie neoprávneného API volania, exfiltráciu dát cez parametre URL alebo únik z pieskoviska).
`cyber_offense_and_cbrn_evals` (Hodnotenie kybernetických a CBRN rizík)	Vysoká	Hodnotí katastrofické riziká dvojakého použitia (systémové riziká podľa EU AI Act): schopnosť autonómne generovať exploity, škodlivý kód alebo asistovať pri vývoji nebezpečných látok (CBRN).	`{"domains": ["Cyber Offense", "CBRN"], "risk_tier": "Medium"}`	**V dokumentácii uvedené pri menej ako 10 % modelov (sekcie *System Card / Frontier Risk*). Povinný test (pre veľké a kódovacie modely):** Spustenie špecifických testov kybernetickej bezpečnosti (**Meta CyberSecEval – Exploit Generation & Insecure Code**) a benchmarku **WMDP**.

Názov atribútu	Priorita	Zdôvodnenie (Bezpečnosť a governance)	Príklad hodnoty / Očakávaný formát	Očakávanie v dokumentácii vs. interné testovanie
known_cves_and_runtime_vulns (Známe CVE a zraniteľnosti kódu)	Vysoká	Sleduje zraniteľnosti vo vlastnom kóde modelu (vyžadujúcom parameter trust_remote_code=True), vlastných tokenizéroch alebo v engine inferencie (vLLM, llama.cpp).	{"trust_remote": true, "cves": ["CVE-2024-XXXX"]}	**Prítomnosť vlastného kódu je zistiteľná z config.json (100 % – kľúč auto_map). Povinný test:** Ak repozitár obsahuje vlastné skripty .py (auto_map), vykoná sa statická analýza bezpečnosti kódu (**SAST: Semgrep / Bandit**) pred načítaním modelu.

6.4 Kategória 4: Prevádzkové hranice a obmedzenia (Operational Boundaries & Limitations)

Kategória definuje prevádzkové limity pre účely riadenia modelových rizík (MRM), profilovanie miery halucinácií, odolnosť voči vyčerpaniu zdrojov (*Model DoS*) a zraniteľnosti súvisiace s viacjazyčným spracovaním.

Tabuľka 8: Špecifikácia atribútov v kategórii Prevádzkové hranice a obmedzenia

Názov atribútu	**Priorita**	**Zdôvodnenie (Bezpečnosť a governance)**	**Príklad hodnoty / Očakávaný formát**	**Očakávanie v dokumentácii vs. interné testovanie**
`out_of_scope_and_prohibited_uses` (Zakázané a neodporúčané použitie)	Kritická	Vymedzuje hranice prípustného nasadenia pre interné tímy. Nasadenie modelu v zakázanej oblasti (napr. riadenie kritickej infraštruktúry, automatizovaná medicínska diagnostika, biometria) porušuje NIST AI RMF a pravidlá EU AI Act pre vysokorizikové systémy.	`["Critical infrastructure", Äutomated medical advice"]` (`Array<String>`)	**Deklaratívny atribút (uvedený pri ≈65 % modelov v sekcii *Out-of-Scope Use / Limitations*).** Technicky sa netestuje; slúži ako vstup pre politický engine (*Policy Engine*), ktorý automaticky zablokuje žiadosť o nasadenie, ak sa účel projektu zhoduje so zakázanou doménou.
`hallucination_and_factuality` (Miera halucinácií a faktická presnosť)	Vysoká	Kvantifikuje riziko konfabulácie. Vysoká miera halucinácií v systémoch RAG alebo v asistentoch pre bezpečnostných analytikov (SOC) môže viesť k nesprávnym zásahom pri riešení incidentov.	`{"TruthfulQA": 64.2, "SimpleQA": 38.1}` (`JSON Object`: Benchmark → Skóre)	**V dokumentácii uvedené pri ≈40 % modelov (evaluačné tabuľky). Povinný test (pre RAG a analytické nasadenia):** Vyhodnotenie na internom referenčnom datasete (**RAG Groundedness / Faithfulness Eval**) overujúcom prísne dodržiavanie poskytnutého kontextu.

Názov atribútu	**Priorita**	**Zdôvodnenie (Bezpečnosť a governance)**	**Príklad hodnoty / Očakávaný formát**	**Očakávanie v dokumentácii vs. interné testovanie**
`context_window_and_degradation` (Kontextové okno a degradácia pozornosti)	Vysoká	Zabraňuje odmietnutiu služby (*Model DoS*) a tichému obídeniu bezpečnostných inštrukcií, pri ktorom sa systémový bezpečnostný prompt „stratí“ alebo oslabí vo veľmi dlhom kontexte (efekt *Lost in the Middle*).	`{"claimed_max": 128000, ëff_ruler":72.4}`	**V `config.json` (`max_position_embeddings`) uvedené vždy (100 %), avšak efektívny kontext býva výrazne kratší. Povinný test:** Test **Many-Shot Jailbreaking / Long-Context Safety Retention** – overenie, či model dodržiava bezpečnostný systémový prompt aj pri zaplnení kontextového okna na 80–90 %.
`compute_and_vram_footprint` (Hardvérové požiadavky a spotreba VRAM)	Stredná	Nevyhnutné pre kapacitné plánovanie, kontrolu nákladov a ochranu pred útokmi vyčerpania výpočtových zdrojov (*Sponge Attacks*) v interných GPU klastroch.	`{"fp16_vram":140, ïnt4_vram": 42}`	**Matematicky odvoditeľné z počtu parametrov a presnosti v `config.json` (100 %). Záťažový test (pri nasadení):** Profilovanie maximálnej spotreby pamäte KV-cache a latencie pri extrémnych vstupoch (**Sponge / Resource Exhaustion Probes**).

Názov atribútu	Priorita	Zdôvodnenie (Bezpečnosť a governance)	Príklad hodnoty / Očakávaný formát	Očakávanie v dokumentácii vs. interné testovanie
`bias_toxicity_and_weak_languages` (Predsudky, toxicita a slabé jazyky)	Vysoká	Útočníci cielene využívajú **nízko-zdrojové a menej rozšírené jazyky** (napr. svahilčina, zuluština, gaelčina, transliterácia), aby obišli bezpečnostné filtre trénované primárne na anglickom jazyku.	`{"RealToxicity": 0.08, "weak_langs": ["Low-resource scripts"]}`	**V dokumentácii sa zraniteľnosť na menej rozšírených jazykoch uvádza v menej ako 5 % prípadov. Povinný test: Multilingual / Cross-Lingual Jailbreak Test** – automatizovaný preklad škodlivých promptov do cieľových jazykov organizácie (vrátane slovenčiny) a sady nízko-zdrojových jazykov na overenie konzistentnosti bezpečnostného zarovnania.

6.5 Architektonické princípy spracovania a prepojenia dôkazov

Na zamedzenie halucinácií samotného extrakčného agenta a zabezpečenie plnej auditovateľnosti sú v architektúre spracovania uplatnené tri riadiace mechanizmy:

1. **Trojstavová epistemická klasifikácia chýbajúcich údajov (`Extracted` | `Explicitly_None` | `Unreported_Omission`):** Agent nesmie zamieňať chýbajúcu informáciu v dokumentácii s negatívnou hodnotou. Ak technická správa neobsahuje zmienku o filtrácii osobných údajov (PII), atribút nadobúda stav `Unreported_Omission` (nezverejnené opomenutie), čo v systéme hodnotenia rizík automaticky aktivuje zvýšenú penalizáciu a vyvolá dynamické testovanie vo Fáze 2.

2. **Priorita technických artefaktov nad deklaratívnym textom (*Artifact vs. Prose Reconciliation*):** V prípade rozporu medzi textovým opisom v `README.md` a skutočnými súbormi v repozitári majú absolútnu prednosť technické artefakty

(`config.json`, `tokenizer_config.json`, prípony súborov váh a text súboru `LICENSE`).

3. **Vynútenie dohľadateľnosti k dôkazom (*Citation & Grounding Enforcement*):** Každý extrahovaný atribút vo výstupnej JSON schéme musí obsahovať štruktúrovaný odkaz na zdrojový dôkaz (`source_evidence`) pozostávajúci z identifikátora dokumentu, čísla strany alebo riadku a presnej citácie úryvku.

Stavy z bodu 1 spresňujú stavy tvrdenia v informačnom modeli profilu: `Extracted` zodpovedá stavu uvedené alebo odvodené, `Explicitly_None` je uvedené tvrdenie so zápornou hodnotou (výrobca výslovne uvádza, že vlastnosť model nemá) a `Unreported_Omission` zodpovedá stavu chýbajúce. Stav rozporné vzniká, keď sa text a technické artefakty nezhodujú (bod 2).

Záver

Kapitola bude doplnená v priebehu riešenia projektu.

Literatúra

1. MITCHELL, M. et al. Model Cards for Model Reporting. In: *FAT* '19: Conference on Fairness, Accountability, and Transparency* [online]. Atlanta, 2019 [cit. 2026-10-20]. Dostupné z arXiv: 1810.03993.
2. LIANG, W. et al. What's documented in AI? Systematic Analysis of 32K AI Model Cards. *Nature Machine Intelligence* [online]. 2024 [cit. 2026-10-20]. Dostupné z arXiv: 2402.05160.
3. HUGGING FACE. *Model Cards* [online]. [cit. 2026-10-20]. Dostupné z: https://huggingface.co/docs/hub/model-cards.
4. WAN, A. et al. *The 2025 Foundation Model Transparency Index* [online]. Stanford CRFM, 2025-12-11. [cit. 2026-10-20]. Dostupné z arXiv: 2512.10169.
5. EURÓPSKY PARLAMENT A RADA EÚ. *Nariadenie (EÚ) 2024/1689, ktorým sa stanovujú harmonizované pravidlá v oblasti umelej inteligencie (akt o umelej inteligencii)* [online]. 2024. [cit. 2026-10-20]. Dostupné z: https://ai-act-service-desk.ec.europa.eu/en/ai-act/article-11.
6. NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. *Artificial Intelligence Risk Management Framework (AI RMF 1.0)* [online]. Gaithersburg, 2023 [cit. 2026-10-20]. NIST AI 100-1. NIST. Dostupné z DOI: 10.6028/NIST.AI.100-1.
7. NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. *AI RMF Playbook* [online]. [cit. 2026-10-20]. Dostupné z: https://airc.nist.gov/airmf-resources/playbook.
8. ISO/IEC. *ISO/IEC 42001:2023 Information technology – Artificial intelligence – Management system* [online]. 2023. [cit. 2026-10-20]. Dostupné z: https://www.iso.org/standard/81230.html.
9. OWASP FOUNDATION. *OWASP Top 10 for LLM Applications 2025* [online]. 2025. [cit. 2026-10-20]. Dostupné z: https://genai.owasp.org/llm-top-10/.
10. MITRE. *MITRE ATLAS: Adversarial Threat Landscape for Artificial-Intelligence Systems* [online]. 2025. [cit. 2026-10-20]. Dostupné z: https://atlas.mitre.org/.
11. MICROSOFT. *Threat Modeling AI/ML Systems and Dependencies* [online]. 2022. [cit. 2026-10-20]. Dostupné z: https://learn.microsoft.com/en-us/security/engineering/threat-modeling-aiml/.

12. MAURI, L.; DAMIANI, E. Modeling Threats to AI-ML Systems Using STRIDE. *Sensors* [online]. 2022, **22**(17) [cit. 2026-10-20]. Dostupné z: https://pmc.ncbi.nlm.nih.gov/articles/PMC9459912/.

13. WEIDINGER, L. et al. Taxonomy of Risks posed by Language Models. In: *2022 ACM Conference on Fairness, Accountability, and Transparency (FAccT '22)* [online]. 2022 [cit. 2026-10-20]. Dostupné z DOI: 10.1145/3531146.3533088.

14. OWASP GENAI SECURITY PROJECT. *AIBOM Generator* [online]. [cit. 2026-10-21]. Dostupné z: https://github.com/GenAI-Security-Project/aibom-generator.

15. OWASP CYCLONEDX. *Machine Learning Bill of Materials (ML-BOM)* [online]. [cit. 2026-10-21]. Dostupné z: https://cyclonedx.org/capabilities/mlbom/.

16. LIU, J.; LI, W.; JIN, Z.; DIAB, M. Automatic Generation of Model and Data Cards: A Step Towards Responsible AI. In: *Proceedings of the 2024 Conference of the North American Chapter of the Association for Computational Linguistics (NAACL 2024)* [online]. 2024 [cit. 2026-10-20]. Dostupné z arXiv: 2405.06258.

17. LIU, J. *AutomatedModelCardGeneration: kód a dátová množina CardBench* [online]. [cit. 2026-10-21]. Dostupné z: https://github.com/jiarui-liu/AutomatedModelCardGeneration.

18. ZHANG, H. et al. AdaQE-CG: Adaptive Query Expansion for Web-Scale Generative AI Model and Data Card Generation. In: *Proceedings of the ACM Web Conference (WWW 2026)* [online]. 2026 [cit. 2026-10-21]. Dostupné z arXiv: 2604.09617.

19. TOMA, T. R.; GREWAL, B.; BEZEMER, C.-P. *Automatic Model Card Generation Using an LLM* [online]. 2026-08-25. [cit. 2026-10-20]. Dostupné z arXiv: 2608.24807.

20. RAO, P. S. B.; ŠĆEPANOVIĆ, S.; ZHOU, K.; BOGUCKA, E. P.; QUERCIA, D. *RiskRAG: A Data-Driven Solution for Improved AI Model Risk Reporting* [online]. 2025-04-11. [cit. 2026-10-20]. Dostupné z arXiv: 2504.08952.

21. GULDIMANN, P. et al. *COMPL-AI Framework: A Technical Interpretation and LLM Benchmarking Suite for the EU Artificial Intelligence Act* [online]. 2024. [cit. 2026-10-21]. Dostupné z arXiv: 2410.07959.

22. WHITE, M.; HADDAD, I.; OSBORNE, C. et al. *The Model Openness Framework: Promoting Completeness and Openness for Reproducibility, Transparency, and Usability in AI* [online]. 2024. [cit. 2026-10-21]. Dostupné z arXiv: 2403.13784.

23. MIT FUTURETECH. *The AI Risk Repository* [online]. [cit. 2026-10-21]. Dostupné z: https://airisk.mit.edu/.

24. CREDO AI. *Credo AI: Product overview* [online]. [cit. 2026-10-20]. Dostupné z: https://www.credo.ai/product.

25. HOLISTIC AI. *AI Governance Platform* [online]. [cit. 2026-10-20]. Dostupné z: https://www.holisticai.com/ai-governance-platform.

26. IBM. *watsonx.governance* [online]. [cit. 2026-10-20]. Dostupné z: https://www.ibm.com/products/watsonx-governance.

27. IBM. *Docling: document parsing* [online]. [cit. 2026-10-20]. Dostupné z: https://github.com/docling-project/docling.

28. PROTECT AI. *ModelScan: Protection against Model Serialization Attacks* [online]. [cit. 2026-10-21]. Dostupné z: https://github.com/protectai/modelscan.

29. UK AI SECURITY INSTITUTE. *Inspect: An open-source framework for large language model evaluations* [online]. [cit. 2026-10-21]. Dostupné z: https://inspect.aisi.org.uk/.

30. NVIDIA. *garak: LLM vulnerability scanner* [online]. [cit. 2026-10-20]. Dostupné z: https://github.com/NVIDIA/garak.

31. MICROSOFT. *PyRIT: Python Risk Identification Tool for generative AI* [online]. [cit. 2026-10-21]. Dostupné z: https://github.com/microsoft/PyRIT.

32. GISKARD. *Giskard: Open-Source Evaluation & Testing library for LLM Agents* [online]. [cit. 2026-10-20]. Dostupné z: https://github.com/Giskard-AI/giskard-oss.

33. HUGGING FACE. *Pickle Scanning* [online]. [cit. 2026-10-21]. Dostupné z: https://huggingface.co/docs/hub/security-pickle.

34. HUGGING FACE. *safetensors: Simple, safe way to store and distribute tensors* [online]. [cit. 2026-10-21]. Dostupné z: https://github.com/huggingface/safetensors.

35. HADFIELD, J. et al. *How we built our multi-agent research system* [online]. Anthropic, 2025-06-13. [cit. 2026-10-21]. Dostupné z: https://www.anthropic.com/engineering/multi-agent-research-system.

36. FOURNEY, A. et al. *Magentic-One: A Generalist Multi-Agent System for Solving Complex Tasks* [online]. Microsoft Research, 2024. [cit. 2026-10-21]. Dostupné z arXiv: 2411.04468.

37. CHEN, G. et al. AutoAgents: A Framework for Automatic Agent Generation. In: *Proceedings of the Thirty-Third International Joint Conference on Artificial Intelligence (IJCAI 2024)* [online]. 2024 [cit. 2026-10-21]. Dostupné z arXiv: 2309.17288.

38. HUGGING FACE. *smolagents* [online]. [cit. 2026-10-21]. Dostupné z: https://github.com/huggingface/smolagents.

39. GGML-ORG. *llama.cpp: LLM inference in C/C++* [online]. [cit. 2026-10-21]. Dostupné z: https://github.com/ggml-org/llama.cpp.

40. LANGCHAIN. *Open Deep Research* [online]. [cit. 2026-10-21]. Dostupné z: https://github.com/langchain-ai/open_deep_research.

41. MADAAN, A. et al. *Self-Refine: Iterative Refinement with Self-Feedback* [online]. 2023-03-30. [cit. 2026-10-20]. Dostupné z arXiv: 2303.17651.

42. STANFORD CRFM. *Foundation Model Transparency Index: indicators (fmti-indicators.csv)* [online]. [cit. 2026-10-22]. Dostupné z: https://github.com/stanford-crfm/fmti.

43. MASOUDIFARD, A.; SOROND, M. M.; MADADI, M.; SABOKROU, M.; HABIBI, E. *Leveraging Graph-RAG and Prompt Engineering to Enhance LLM-Based Automated Requirement Traceability and Compliance Checks* [online]. 2024-12-11. [cit. 2026-10-20]. Dostupné z arXiv: 2412.08593.

44. AGARWAL, B.; JOMRAJ, H. S.; KAPLUNOV, S.; KROLICK, J.; ROJKOVA, V. *RAGulating Compliance: A Multi-Agent Knowledge Graph for Regulatory QA* [online]. 2025-08-13. [cit. 2026-10-20]. Dostupné z arXiv: 2508.09893.

45. ROMAN, M.; RAFFERTY, K.; DEVEREUX, B. *CTRAG: An In-Context Retrieval-based Framework for Automated Compliance Checking using LLMs* [online]. 2026-08-03. [cit. 2026-10-20]. Dostupné z arXiv: 2608.02472.

46. HUGGING FACE. *huggingface_hub: Repository Cards* [online]. [cit. 2026-10-20]. Dostupné z: https://huggingface.co/docs/huggingface_hub/package_reference/cards.

47. OLLAMA. *Ollama: Documentation* [online]. [cit. 2026-10-20]. Dostupné z: https://github.com/ollama/ollama.

48. VLLM. *vLLM Documentation* [online]. [cit. 2026-10-20]. Dostupné z: https://docs.vllm.ai/.

49. INSTRUCTOR. *Instructor: Structured outputs for LLMs* [online]. [cit. 2026-10-20]. Dostupné z: https://python.useinstructor.com/.

50. DOTTXT. *Outlines: Structured text generation* [online]. [cit. 2026-10-20]. Dostupné z: https://github.com/dottxt-ai/outlines.

51. PGVECTOR. *pgvector: Open-source vector similarity search for Postgres* [online]. [cit. 2026-10-20]. Dostupné z: https://github.com/pgvector/pgvector.

52. HOLISTIC AI. *holisticai: open-source library* [online]. [cit. 2026-10-20]. Dostupné z: https://github.com/holistic-ai/holisticai.

53. IBM TECHNOLOGY. *What is Retrieval-Augmented Generation (RAG)?* [YouTube]. [cit. 2026-10-20]. Dostupné z: https://www.youtube.com/watch?v=T-D1OfcDW1M.

54. CONFIDENT AI. *OWASP Top 10 2025 for LLM Applications: Risks and Mitigation Techniques* [online]. [cit. 2026-10-20]. Dostupné z: https://www.confident-ai.com/blog/owasp-top-10-2025-for-llm-applications-risks-and-mitigation-techniques.

55. YAO, S. et al. ReAct: Synergizing Reasoning and Acting in Language Models. In: *International Conference on Learning Representations (ICLR)* [online]. 2023 [cit. 2026-10-20]. Dostupné z arXiv: 2210.03629.

56. SHINN, N. et al. *Reflexion: Language Agents with Verbal Reinforcement Learning* [online]. 2023-03-20. [cit. 2026-10-20]. Dostupné z arXiv: 2303.11366.

57. YAN, S.-Q.; GU, J.-C.; ZHU, Y.; LING, Z.-H. *Corrective Retrieval Augmented Generation* [online]. 2024-01-29. [cit. 2026-10-20]. Dostupné z arXiv: 2401.15884.

58. HABIBZADEH, A.; FEYZI, F.; EBRAHIMI ATANI, R. Large Language Models for Security Operations Centers: A Comprehensive Survey. *Journal of Electrical and Computer Engineering* [online]. 2026, (3383674) [cit. 2026-10-20]. Dostupné z arXiv: 2509.10858.

59. LANGCHAIN. *LangSmith* [online]. [cit. 2026-10-20]. Dostupné z: https://smith.langchain.com/.